

## Checklist

# Understanding IDSs and IPSs

## IDS vs. IPS

- Remember: an **IDS detects, logs, and alerts** on suspicious activity.
- Remember: an **IPS can detect and actively block or disrupt** suspicious traffic.
- IDS = visibility and alerting; IPS = visibility plus prevention.
- IDS/IPS tools complement endpoint security such as antivirus and EDR.
- Alerts should always be reviewed in context before deciding whether activity is malicious.
- Threat intelligence feeds can help determine whether an IP address, domain, or behavior is suspicious.

## Network-Based IDS (NIDS)

- A **NIDS monitors network traffic** rather than activity on just one computer.
- NIDS sensors should be placed where important traffic can be observed.
- **Promiscuous mode** allows a network interface to listen to traffic passing across the network.
- **Snort** is commonly used for signature-based network intrusion detection and prevention.
- **Snort 3** supports multithreading for improved performance.
- **Suricata** is multithreaded and designed for high-speed network monitoring.
- Suricata can perform file extraction, protocol analysis, and TLS-related inspection.
- **Zeek** focuses heavily on network analysis, logging, and visibility.
- Zeek can work alongside tools such as Snort and Suricata rather than replacing them.
- Choose between Snort, Suricata, and Zeek based on the environment and monitoring goals.

## Host-Based IDS (HIDS)

- A **HIDS monitors activity on an individual host or endpoint**.
- HIDS tools can watch files, processes, system changes, and network connections.
- **OSSEC** is an example of a host-based intrusion detection tool.
- File integrity monitoring compares current files with known-good values or hashes.
- Unexpected changes to important files can indicate compromise.
- **osquery** allows administrators to query endpoint information using SQL-like commands.
- Remember that HIDS and **EDR** can overlap, but EDR normally provides stronger response and remediation features.
- Endpoint monitoring is especially useful when network monitoring cannot see everything happening on the device.

## Honeypots

- A **honeypot is a decoy system or service designed to attract attackers**.
- Honeypots should be isolated and closely monitored.
- Unexpected interaction with a honeypot is usually suspicious.
- Honeypot alerts often have a high signal-to-noise ratio.
- Examples include **Cowrie, OpenCanary, MySQLpot, and NoPo**.
- Honeypots should supplement other security controls, not replace them.

## Intrusion Prevention Systems

- An IPS is commonly placed **inline** so traffic passes through it.
- Inline placement allows the IPS to stop malicious traffic before it reaches its destination.
- IPS decisions can be based on signatures, behaviors, anomalies, and other detection methods.
- Some systems attempt to interrupt suspicious connections using **TCP reset packets**.
- TCP reset techniques are generally less reliable than true inline blocking.
- Snort can be configured for active response or prevention.
- Always consider the possibility of false positives before allowing automatic blocking.

## Next-Generation Firewalls

- An **NGFW combines traditional firewall functions with more advanced security features.**
- NGFWs often include built-in IDS/IPS capabilities.
- Common features include application awareness, application control, identity tracking, and threat detection.
- Some NGFWs can inspect encrypted traffic.
- NGFWs can reduce the need for separate security appliances in smaller environments.
- An NGFW is not automatically the best choice for every organization.
- Consider network size, architecture, security requirements, scalability, and budget before choosing a product.
- Common vendors include Cisco, Check Point, Palo Alto Networks, Fortinet, SonicWall, and Sophos.

## IDS/IPS in the Cloud

- Cloud environments change rapidly, so IDS/IPS monitoring must adapt with them.
- Traditional static monitoring can struggle with containers, microservices, and dynamically created workloads.
- Cloud IDS/IPS solutions should integrate with cloud-native platforms and orchestration tools where possible.
- Kubernetes environments may require monitoring that understands container and workload lifecycle changes.
- Virtual network taps or similar mechanisms can be used to send cloud traffic to IDS/IPS systems.

## AWS Reminders

- **Amazon GuardDuty** provides managed threat detection.
- GuardDuty uses threat intelligence, anomaly detection, and machine learning.
- **AWS CloudTrail** records account and API activity.
- **VPC Flow Logs** provide information about network traffic.
- **Amazon EventBridge** can help route security-related events.
- Remember that third-party IDS/IPS products can also be deployed in AWS.

## Azure Reminders

- **Microsoft Defender for Cloud** provides security monitoring and threat detection.
- **Microsoft Sentinel** provides SIEM and security analytics capabilities.
- **KQL** is commonly used to query Microsoft security and logging data.
- **Azure Activity Logs** record subscription-level activity.
- **Azure Resource Logs** provide information about individual resources.
- **Azure Monitor Logs** can centralize and analyze logging data.

## GCP Reminders

- **Event Threat Detection (ETD)** analyzes Google Cloud logging data for suspicious activity.
- ETD findings can appear in **Security Command Center**.
- **Cloud Audit Logs** record administrative and access-related activity.
- **Cloud Logging** collects logs from Google Cloud services and workloads.
- Firewall, network, and security logs should be reviewed together for better context.

## Alert Management

- Too many alerts can cause **alert fatigue**.
- Focus attention on alerts that provide useful and actionable information.
- A **false positive** is an alert for activity that is not actually malicious.
- A legitimate event can still be noisy if it occurs too frequently.
- Do not automatically disable a rule simply because it generates many alerts.
- Adjust thresholds, IP ranges, ports, severity levels, or exclusions when appropriate.
- Consider logging low-priority events instead of generating immediate alerts for all of them.
- IDS/IPS tuning is an **ongoing process**, not a one-time configuration task.

## Snort Rule Reminders

- Remember the basic structure: **action + protocol + source + destination + rule options**.
- **msg** = message shown when the rule triggers.
- **sid** = unique signature ID.
- **rev** = rule revision number.
- **content** = data the rule should search for.

- **offset** = where the content search should begin in the packet.
- **flow** = direction or state of the network connection.
- More specific rules usually create fewer false positives.
- Test custom rules before deploying them broadly.
- **PCAP files** can be useful for testing and validating detection rules.

## IDS/IPS Placement

- IDS/IPS placement determines which traffic can actually be inspected.
- Place sensors at important **network choke points**.
- Monitoring the internet connection provides visibility into inbound and outbound traffic.
- Perimeter monitoring alone may miss traffic moving between internal systems.
- Monitoring the **DMZ** can improve visibility into public-facing systems.
- Internal monitoring can help detect lateral movement.
- Large numbers of VLANs can make complete monitoring more difficult and expensive.
- Choose placement based on the network topology and the threats you are most concerned about.
- Microsegmented networks may require multiple monitoring points or other security technologies.

## Encrypted Traffic

- IDS/IPS tools cannot normally inspect encrypted payload contents without decryption.
- Encryption can hide malicious activity from network monitoring tools.
- Some attacks can still be detected using visible connection information or unencrypted portions of traffic.
- **SSL/TLS inspection** can provide deeper visibility into encrypted traffic.
- TLS inspection introduces performance overhead.
- Decrypting traffic can create privacy, compliance, or legal concerns.
- Some NGFWs include built-in SSL/TLS inspection.
- Snort and Suricata can be used with proxies that decrypt traffic.
- **JA3 fingerprints/hashes** can help identify TLS clients or suspicious encrypted connections without reading the encrypted payload.

## Final Reminders

- **IDS = detect and alert.**
- **IPS = detect and prevent.**
- **NIDS = monitor the network.**
- **HIDS = monitor the host.**
- EDR adds endpoint detection plus response capabilities.
- Honeypots provide decoy systems that help expose attacker behavior.
- NGFWs combine firewalling with advanced security functions.
- Cloud environments require adaptable monitoring.
- Reduce false positives so important alerts are easier to recognize.
- Put IDS/IPS sensors where they can see the traffic that matters.
- Remember that encrypted traffic limits visibility unless additional inspection techniques are used.
- IDS/IPS tools should be part of a **larger layered security strategy**.
- Logs and alerts only provide value when someone reviews them and knows how to respond.